Problems met while building the cases, and what to add

Everything below came up while driving the board through the two worked cases (the Okta vishing wave and the SafePay ransomware advisory) and the feature run. Each item says what happened, why it matters to an analyst, and what would fix it. Items marked **fixed** are already changed in this repo.

Bugs found (fixed in `src/logic.js`)

1. **Board export, case brief and one-pager crashed when the case had a cluster.** `renderBoard()` drew the cluster rectangles before the canvas context existed. Fixed by drawing them after the context is created and translated. Any case that used "+ Cluster" could not be exported or briefed before this.
2. **The passphrase lock screen crashed on load.** The locked initial state lacked the `extract`, `newFrom`, `newTo` and `newRel` fields that the template reads. Encrypted cases could not be opened again. Fixed by initialising them.

Friction an analyst will hit

3. **Esc does nothing while the cursor is in a text box.** Keyboard shortcuts are suppressed inside inputs, including Esc, so the OSINT workbench, ACH or a modal cannot be closed with Esc straight after typing in them; you have to click Close. *Addressed:* Esc now blurs the field and closes the panel; other shortcuts stay suppressed while typing.
4. **Quick-add help text is incomplete.** The box lists `d i h u e n p t c`, but the parser also accepts `m` (email), `w` (wallet), `cve`, `@` (handle), `l` (location), `doc`, `x` (transfer) and `org` (target). Typing `tx …` silently creates a note. *Addressed:* `?` lists every command, unknown short commands are refused with a hint, four-letter commands (`host`, `file`, `mail`, `code`, `feed`) now parse (they never did), and `f` / `host` add file-name and hostname indicators.
5. **Extract IOCs and CSV import do not recognise hostnames or file names.** The SafePay advisory lists hostnames (`WIN-SBOE3CPNAL`) and dozens of file names (`locker.dll`, `sharefinder.ps1`, `Socks_werfault.exe`); none can become indicator cards, so they had to go into a note. Add `hostname` and `filename` indicator kinds (with YARA / Sigma-friendly export) and let Extract pick them up. The CSV importer maps a `hostname` column to the Domain kind, so Windows computer names end up labelled as domains, and it silently skips any value already on the board without saying which ones.
6. **SHA-1 and SHA-256 are both just "hash".** The card does not say which algorithm it holds, and STIX export has to guess from the length. Keep the algorithm on the card and in the pattern.
7. **Extract IOCs does not de-duplicate against the board.** Running it twice on overlapping text creates duplicate cards that then need Merge. Skip values that already exist in the case, or offer "update existing".
8. **CDN and SaaS addresses are not flagged.** Several IPs in the CISA table belong to Cloudflare, GitHub and Google ranges. The board pins them like any other IOC; nothing warns that blocking

them would be wrong. An ownership lookup on pin (ASN / org, already available through RDAP in the workbench) with a "shared infrastructure" badge would prevent bad blocklists.

9. **Most OSINT lookups are blocked in the browser.** crt.sh, urlscan, ThreatFox, MalwareBazaar, Wayback and VirusTotal refuse cross-origin requests, so only Google DNS, RDAP and NVD return live; everything else is a launcher link, and VirusTotal shows a captcha when opened. The backend in `BACKEND-SPEC.md` (server-side keys, cached results, enrichment landing as inbox cards) is the real fix; until then a small proxy for the free endpoints would already make the workbench much more useful.
10. **The ATT&CK table is a short local list.** Only about 45 techniques resolve to a name and tactic; `T1569.002`, `T1548.002`, `T1560.001`, `T1048`, `T1490`, `T1218`, `T1134.001` from the SafePay advisory came in as bare IDs, which the kill-chain view cannot lane. Ship the full Enterprise matrix (or fetch it once and cache it) and let the user pick a tactic when the ID is unknown.
11. **The actor library is static and small.** SafePay, Akira, Qilin, Medusa and other current ransomware operations are absent, so the only option was to drop in LockBit as a comparison and stamp it False lead. Let analysts add actors, import them from STIX intrusion-sets, or load a MISP galaxy.
12. **New cards pile up in the middle of the board.** Pinning twenty extracted indicators produces a stack that must be dragged apart by hand. *Addressed:* new pinned cards fill a grid beside the board's bounding box, skipping occupied spots.
13. **Moving a card does not bring its cluster along, and clusters are geometric only.** Membership is "centre inside the rectangle", so a card that drifts out silently leaves the cluster, and resizing can capture unrelated cards. Explicit membership (drag onto cluster, listed in the panel) would be more predictable.
14. **Thread suggestions only look at shared tags and tokens.** They did not suggest linking the soc.dll hash to its C2 address even though the advisory ties them together. Suggestions from the OSINT results (resolutions, certificate SANs, same ASN) and from indicators appearing in the same source card would catch more.
15. **Events have a day but no time.** The SafePay timeline (16:05 ET drain, 17:01 freeze, …) in the sample case can only be ordered by day. Add an optional time to event cards and sort the timeline by it.
16. **Pictures live inside the case as data URLs.** Images are shrunk to 900 px and embedded, so a case with maps and captures grows quickly; `localStorage` has a hard ceiling of a few megabytes per origin and snapshots copy the images again. Store files separately (IndexedDB now, object storage with the backend) and keep only a reference on the card.
17. **No case-level metadata beyond title and TLP.** There is no owner, no tags or sector, no related-case links and no "source advisory" field, so the case list cannot be filtered or grouped. Add a small header block and show it in the case switcher.
18. **Search has no filters and no scope.** Cross-case search is useful, but there is no way to search only indicators, only a tag, or only the current case, and no saved searches. Add type / tag / case filters and remember recent queries.
19. **Transfers need addresses to be useful.** The transfer card links to a block explorer only when a tx hash or address is present; public advisories often give amounts without addresses. Allow an amount-only transfer to still appear in the brief's financial summary, and let several transfers roll up into a total.
20. **Merge is manual, one card at a time.** After an actor drop-in or a second extraction there can be many duplicates. A "find duplicates" button (same value, same technique ID, same title) with a merge-all review would save time.
21. **ACH has no scoring summary.** Cells can be marked, and the count of inconsistencies is shown per hypothesis, but there is no weighting by evidence grade and the matrix is not in the case brief.

Weight by Admiralty grade and print the matrix.

22. *(still open)* **The request letter cannot be sent or tracked.** Open letter / Copy text is all there is; the Requests count in the audit is not tied to a card. Record each generated request as a task with a reference number and a due date.
23. **"Analyse with Claude" only works in the Claude app preview.** Elsewhere the button just shows a toast. With a backend key (see `/v1/ai/assess` in the spec) it could run anywhere, and the assessment could be stored on the card instead of only shown.
24. **Mobile is read-mostly.** Narrow screens get a list, but cards cannot be arranged or connected and the OSINT workbench is cramped. Fine for review; say so in the UI.
25. **Single-letter shortcuts fire while a button has focus.** After clicking a toolbar button, pressing `t` or `k` toggles a layout even though the user is not "on the board". Scope shortcuts to the board or require focus there.

Things that worked well and are worth keeping

- Extract IOCs with defanged input, the OSINT workbench's type detection, the Audit tab's backlog, snapshots with diff, playback, the brief and one-pager, and the STIX round trip all behaved as designed and needed no workaround.
- RDAP and NVD lookups return real data from the browser without keys; the Vilnius / Falkenstein locations on the SafePay board and the CVE descriptions came from them.

Version 2 (login, desk, board with media and feeds) and the server

Found while porting the second design package and putting the server behind it.

26. **The design's accounts were browser-local.** `auth.js` kept PBKDF2 hashes, sessions and the audit in `localStorage`, so anyone with the device had every account and every case. Replaced by server-side scrypt hashes, HttpOnly session cookies with idle and absolute expiry, lockout, rate limits, CSRF checks and a hash-chained audit (`docs/BACKEND.md`). The pages were not changed: the same `window.CIBAuth` surface is served from the server.
27. **A temporary password should unlock nothing but the password change.** The prototype let a user with `mustChange` keep working if they skipped the change screen. The server now refuses every other request until the password is changed.
28. **The board used a public third-party CORS proxy** (`api.allorigins.win`) for live lookups, which means every selector an analyst searched for was sent to an unrelated service. It now goes through the server's allow-listed proxy with an SSRF guard, and provider keys (ThreatFox, VirusTotal, Shodan, GreyNoise, AbuseIPDB, urlscan) are attached server-side.
29. **abuse.ch APIs need a key now.** ThreatFox, URLhaus and MalwareBazaar answer 401 without an `Auth-Key`; the live-feed and hash lookups only work once `THREATFOX_AUTH_KEY` is set. The UI shows "blocked" rather than "needs a key"; it should say which.
30. **Fresh accounts re-seeded the sample cases.** With an empty visible set the board created "Operation Lantern" and the Binance case again, and the server then rejected them as not visible. The store layer now tells the board whether the whole server is empty; later users start with one blank case.
31. **Encrypt-at-rest in the browser and server sync do not mix.** An encrypted local store cannot be pushed; the server is the system of record. The button should either be removed in server mode or re-pointed at per-case server-side encryption with a key the user holds.
32. **Hover styles with `{{ }}` holes were silently dropped** (`style-hover="background:{{ T.accent }}"` on the desk and board): the runtime wrote the literal braces into CSS, so those hover states

never applied in the design either. A theme-aware hover needs a CSS variable (`--accent`) rather than a template hole.

33. **Media files are not tied to a case.** Uploads are stored per card id, so file reads are allowed to any signed-in account; TLP applies to the case, not to the file. *Addressed:* uploads now carry the case id and reads run `canSee` on that case; files uploaded before this change remain account-only.
34. **Desk and board keep separate copies of preferences.** Theme, lamp, drawer state and analyst name live in `desk.v1` and `settings.v1`; they are now saved per user on the server, but a change on one page shows on the other only after a reload.
35. **Live updates were last-writer-wins per case.** *Addressed:* stale saves are now merged three ways on the server (per field, per card) and every save is a restorable revision; presence and soft locks show who is editing what. True per-item operations (spec §3) remain the cleaner long-term design.
36. **The AI gateway's offline engine is rule-based.** Assess, entities and stance are useful without a key; translation is not possible offline and says so. A local model (or a translation service) behind the same endpoint would close that gap without touching the pages.
37. **Node's built-in SQLite is still experimental.** It avoided a native build step, but a production deployment should pin the Node version (22.x) or swap `src/db.js` to better-sqlite3 / Postgres; the schema is small.
38. **Rule-based research is noisy without a model.** Named-entity rules take any two capitalised words as a person ("Veeam Backup"), and news search for a fictional case returns unrelated pages. The panel shows confidence and source for every card and starts low-confidence ones unticked, but with a model key the proposals are far cleaner. GDELT is slow (often over 10 s) and times out on a busy minute.

Version 5 (security and operations)

39. **TOTP recovery codes are missing.** A lost phone means asking an admin to remove the factor from Operations. One-time recovery codes shown at setup would let people recover on their own; store them hashed like passwords.
40. **SSO was tested against a signed test token, not a live provider.** Claims differ between providers (Entra sends `preferred_username`, some send no `email` without the scope). The callback already falls back to `userinfo`, but the first real login should be watched in the audit log.
41. **Erasure is still manual.** The personal-data export finds every mention; deleting a person means editing each case, which creates a revision that still holds the data. A real erasure needs revision scrubbing for that case, which is deliberately not automatic.
42. **Backups are local snapshots.** `data/backups` sits next to the database; a disk loss takes both. Point `CIB_DATA_DIR` at mounted storage or copy the snapshots off the host from a cron job (`npm run backup` prints the path).
43. **Retention counts from the delete, not from the last activity.** A case nobody has opened in years is kept forever unless deleted; an age-based archive rule (move to ARCHIVED after N months idle, then to the wastebasket) would complete the lifecycle.
44. **The legal-hold toggle lives in the Operations drawer, not on the folder.** Fine for a few cases; with hundreds an admin would want the Hold button on the folder's back face and a HELD filter chip on the desk.
45. **Docker build not verified here.** The capture environment has no Docker daemon, so `Dockerfile` and `docker-compose.yml` are written from the working local setup but have not been built. Run `docker compose build` once before relying on them.

Version 6 (reporting, integrations, AI drafts)

46. **OpenCTI has no direct push.** MISP, TheHive and Jira are covered; OpenCTI's import API needs a connector or a multipart upload work item, so for now it consumes the per-case STIX bundle or polls a feed. A native push is a small addition once a test instance is available.
47. **Feeds are full snapshots, not deltas.** Each pull returns every matching indicator; a consumer that wants only changes should diff by STIX id (stable across pulls) or use `?since=` once that is added (`updated_at` is already stored per case).
48. **Ingested PDFs need a text layer.** Scanned PDFs return "no text layer"; an OCR step (tesseract behind the same endpoint) would cover them. Email ingestion handles one message per `.eml`; `.mbox` and `.msg` are not parsed.
49. **Drafts cite exhibits only as well as the model does.** The rules engine quotes exhibit numbers mechanically; a model is asked to, but nothing verifies that every "E12" it writes exists. A post-check that strips or flags unknown exhibit references would make the summary safer to paste into a report.
50. **ACH weights are per evidence row, not per cell.** Diagnosticity usually differs per hypothesis; a per-cell weight (or a credibility weight on the source grade) would be the next refinement, and the brief should print the weight next to each row.
51. **Timeline shows order but not the clock.** Cards on the same day now stack by time, but the axis still labels the day only; a time label under each card in the column (and a toggle for the viewer's time zone versus UTC) is the natural follow-up.
52. **Integration pushes are one-way.** A MISP event or Jira issue created from the board is linked, but later changes on either side are not reflected. A watcher on the Jira status or the MISP event's attribute count would close the loop using the existing watcher scheduler.

Version 7 (sharing and review)

53. **Share links are per case and all-or-nothing.** A link shows every pinned card; a reader-specific view (only indicators, or only the storyboard) would need per-link scopes. The projection already has the switches, the link form does not expose them yet.
54. **Guest identity is a typed name.** Nothing stops a reader from typing another name; for partners who comment often, a per-link passphrase or a magic-link email would tie comments to a person.
55. **Comments do not thread.** One reply per comment, no discussion below it. Threads with resolve/unresolve, and the ability to turn an accepted comment into a card or a task in one click, are the next step.
56. **The public page is not cached or rate-limited for bursts.** A link posted widely hits the API once per view; a short server-side cache of the projection per share id would carry that comfortably.
57. **No notification back to the guest.** When a comment is accepted or replied to, the guest only finds out by revisiting. An optional email on the form would close the loop (and give a reply address).